W14D1 – Password cracking e malware

Studente: Riccardo Luzzi

Corso: Cyber Security

Sistema utilizzato: Kali Linux

Strumenti utilizzati: DVWA, John the Ripper, RockYou, VirtualBox, pfSense

Target: Metasploitable – 192.168.51.101

Scenario di rete: Kali 192.168.50.100 e Metasploitable 192.168.51.101, su reti differenti instradate tramite pfSense

Introduzione

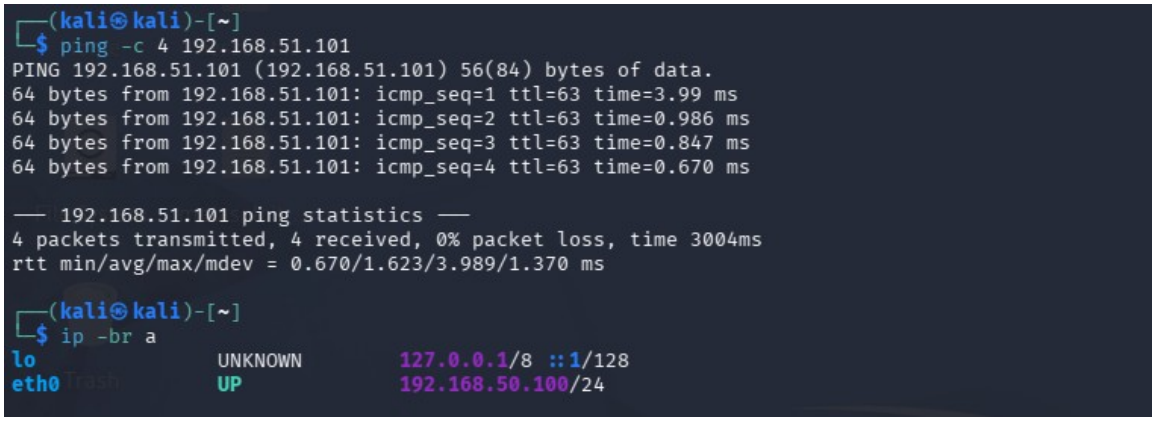
L’esercitazione W14D1 riprende il lavoro svolto nel W13D4 sulla SQL Injection di DVWA. In quell’occasione avevo recuperato dalla tabella users cinque username con i relativi hash delle password. Questa volta l’obiettivo era provare a risalire alle password in chiaro utilizzando John the Ripper su Kali Linux. Ho eseguito prima una sessione con le modalità predefinite di John e poi un secondo tentativo con la wordlist RockYou, confrontando i risultati.

Ho svolto anche la parte facoltativa dedicata a WannaCry come analisi di un possibile incidente aziendale. Non ho eseguito il malware: ho descritto le azioni da intraprendere e valutato vantaggi e limiti delle possibili soluzioni.

1. Verifica del laboratorio

Ho controllato la configurazione di rete di Kali, che risultava 192.168.50.100, e la raggiungibilità di Metasploitable. Il ping verso 192.168.51.101 ha ricevuto quattro risposte su quattro, senza perdita di pacchetti. John the Ripper era già installato nella versione 1.9.0-jumbo-1.

Figura 1 – Indirizzo IP di Kali e ping verso Metasploitable

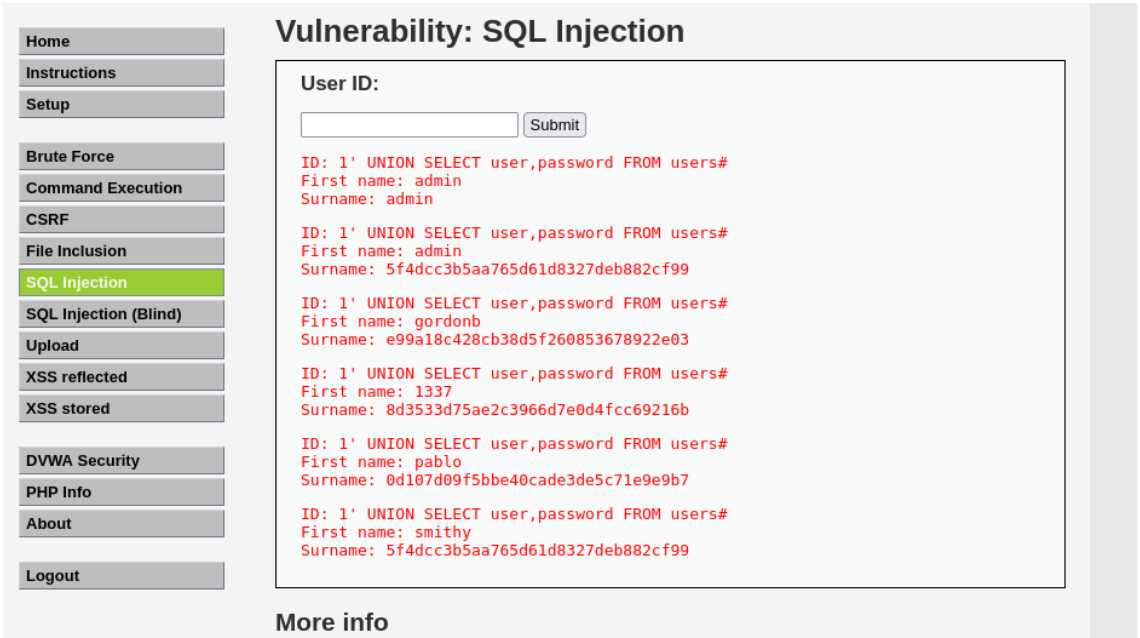


2. Recupero degli hash da DVWA

Con DVWA impostato sul livello di sicurezza Low, ho riutilizzato la SQL Injection già verificata nel W13D4. La query UNION SELECT ha mostrato gli username e i valori memorizzati nella colonna password della tabella users. I valori ottenuti erano hash MD5, non password leggibili.

```
1' UNION SELECT user,password FROM users#
```

Figura 2 – SQL Injection: cinque account e relativi hash MD5

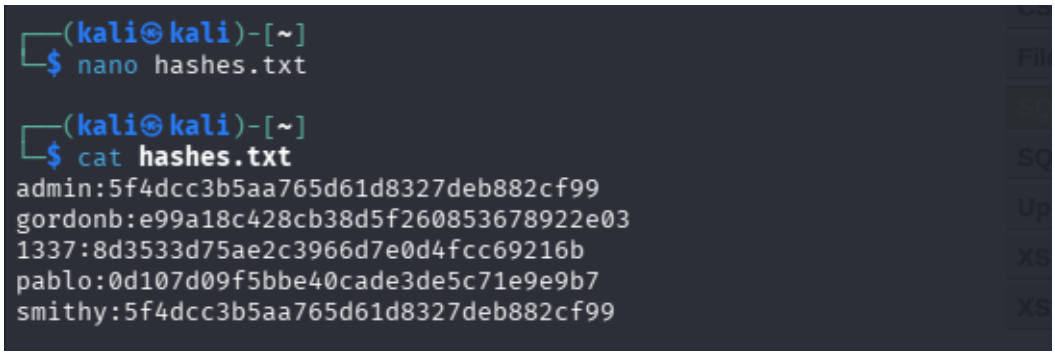


3. Preparazione del file per John the Ripper

Ho creato nella home di Kali il file hashes.txt con una riga per ciascun account, nel formato username:hash. Ho verificato il contenuto con cat prima di avviare il cracking. I cinque account corrispondono a quattro hash distinti: admin e smithy hanno infatti lo stesso valore MD5.

```
nano hashes.txt
cat hashes.txt
```

Figura 3 – Contenuto del file hashes.txt verificato da terminale

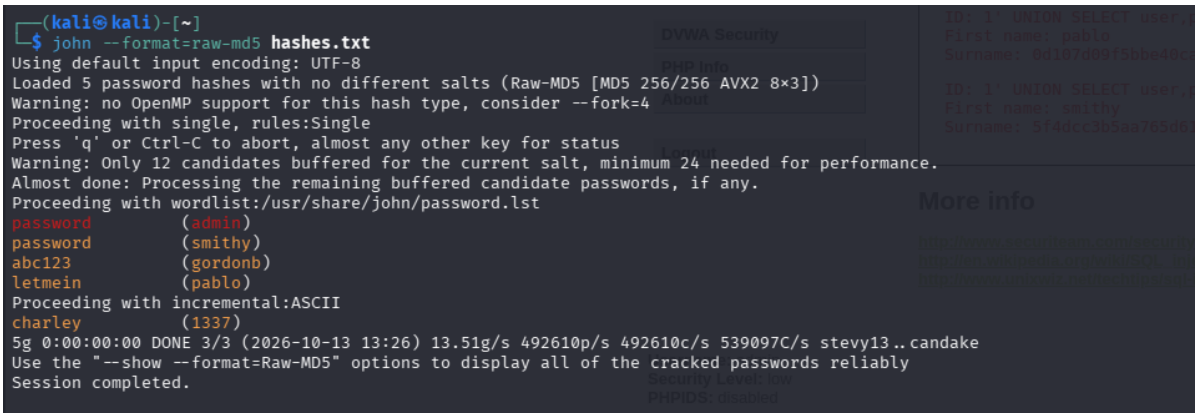


4. Cracking con le modalità predefinite

Ho avviato John indicando il formato raw-md5 senza specificare una wordlist esterna. John è passato attraverso le modalità Single, Wordlist con il dizionario password.lst e Incremental. Durante la fase Wordlist ha recuperato password, abc123 e letmein, mentre charley è stata trovata nella fase Incremental. In totale sono stati risolti tutti e cinque gli account. L'avviso sulle prestazioni del buffer non ha impedito il completamento della prova.

```
john --format=raw-md5 hashes.txt
```

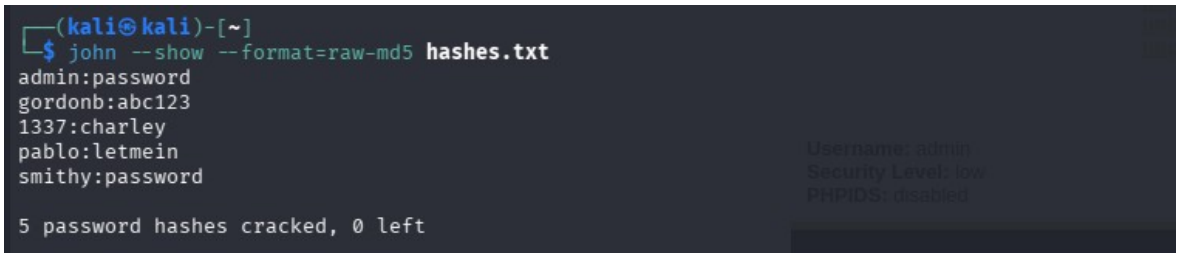
Figura 4 – Esecuzione di John: cinque password recuperate



Successivamente ho utilizzato l’opzione --show per controllare le corrispondenze trovate. Il riepilogo finale riportava cinque account risolti e nessuno rimanente.

```
john --show --format=raw-md5 hashes.txt
```

Figura 5 – Verifica finale con john --show: 5 password recuperate, 0 rimaste

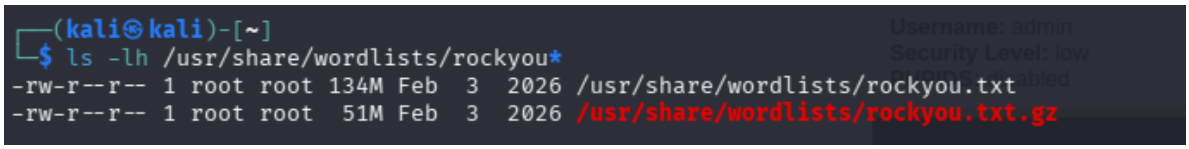


5. Seconda prova con la wordlist RockYou

Per confrontare il primo risultato con un attacco a dizionario esplicito, ho controllato la presenza di RockYou. Su Kali era disponibile soltanto l’archivio rockyou.txt.gz; l’ho quindi decompresso mantenendo anche il file originale. Una nuova verifica ha mostrato sia il dizionario testuale da 134 MB sia il file compresso da 51 MB.

```
ls -lh /usr/share/wordlists/rockyou*
sudo gzip -dk /usr/share/wordlists/rockyou.txt.gz
```

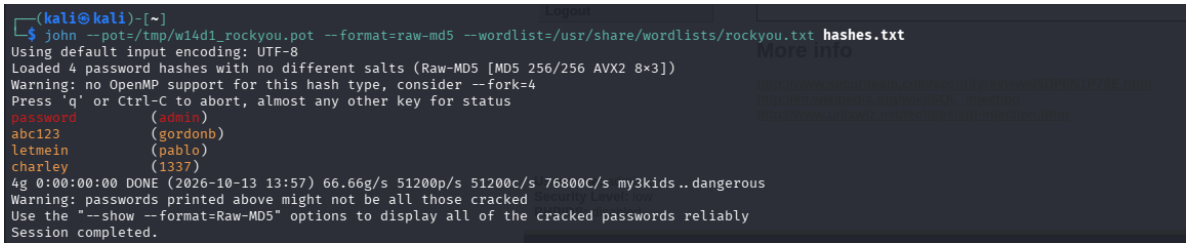
Figura 6 – Verifica della wordlist RockYou dopo la decompressione



Ho avviato una seconda sessione usando la wordlist e un file pot separato, così da non riutilizzare i risultati salvati dalla prima prova. John ha trovato quattro password per quattro hash distinti. Non è una differenza rispetto ai cinque utenti: lo stesso hash, usato da admin e smithy, viene calcolato una sola volta.

```
john --pot=/tmp/w14d1_rockyou.pot --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
```

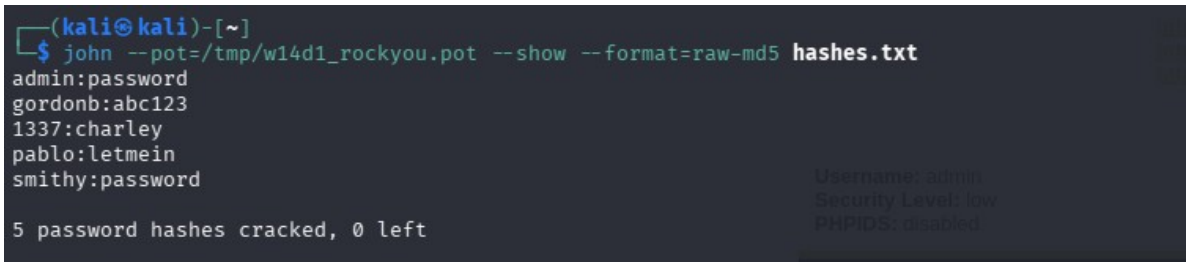
Figura 7 – Cracking con RockYou: quattro hash MD5 distinti risolti



Anche il controllo finale con --show ha confermato tutte e cinque le coppie account/password, con zero hash rimasti da risolvere.

```
john --pot=/tmp/w14d1_rockyou.pot --show --format=raw-md5 hashes.txt
```

Figura 8 – Verifica dei risultati della sessione RockYou



6. Risultati e considerazioni

Utente	Password recuperata
admin	password
gordonb	abc123
1337	charley
pablo	letmein
smithy	password

In entrambe le prove sono state recuperate le password di tutti gli account del laboratorio. La prima sessione ha usato le modalità predefinite di John; nella seconda ho impiegato un attacco a dizionario basato su RockYou. Questi risultati mostrano quanto password comuni, memorizzate con hash MD5 non salati, possano essere esposte a un attacco offline. Un sistema reale dovrebbe usare password robuste e un algoritmo dedicato alla memorizzazione delle password, con salt individuale e costo configurabile.

7. Parte facoltativa – Intervento su un sistema infetto da WannaCry

Nel caso ipotizzato dalla traccia, un computer Windows aziendale risulta infetto da WannaCry. Come primo intervento isolerei immediatamente il dispositivo dalla rete, scollegando Ethernet e Wi-Fi e impedendo l'accesso alle condivisioni. Avviserei il responsabile IT, registrerei i sintomi e cercherei di preservare le evidenze dell'incidente. Non spegnerei indiscriminatamente il computer prima di valutare le esigenze di contenimento e analisi.

WannaCry è un ransomware che cifra i file e si è diffuso sfruttando sistemi Windows vulnerabili attraverso SMBv1, in particolare la falla corretta dalla patch MS17-010. Dopo l'isolamento del PC controllerei gli altri dispositivi aziendali e gli eventuali backup, evitando di collegare supporti di ripristino alla macchina compromessa.

7.1 Possibilità di messa in sicurezza

Intervento	Vantaggi	Limiti
Isolamento dalla rete	Riduce il rischio di diffusione	Interrompe i servizi di rete
Analisi con strumenti di sicurezza	Aiuta a rilevare e rimuovere componenti malevoli	Non decifra automaticamente i file
Ripristino da backup pulito	Permette di recuperare dati senza pagare	Dipende dalla disponibilità di copie integre
Reinstallazione di Windows	Consente di ripartire da un sistema affidabile	Richiede tempo; dati locali non salvati a rischio
Patch MS17-010 e disattivazione SMBv1	Riduce l'esposizione alla vulnerabilità	Non recupera i file già cifrati
Firewall e segmentazione	Limitano la comunicazione tra sistemi	Richiedono configurazione e verifiche

7.2 Soluzione scelta

Dopo aver contenuto l'incidente e raccolto le evidenze utili all'analisi, la soluzione che preferirei sarebbe reinstallare Windows da supporti affidabili e recuperare i dati da un backup precedente all'infezione, dopo aver verificato che sia integro e pulito. Prima di riportare il computer in rete applicherei gli aggiornamenti di sicurezza, disabiliterei SMBv1 dove presente e controllerei le regole firewall. Non considererei il pagamento del riscatto una soluzione affidabile, perché non garantisce la restituzione dei dati.

8. Conclusioni

Il W14D1 mi ha permesso di completare il lavoro iniziato con la SQL Injection: prima ho estratto gli hash dalla tabella users di DVWA, poi ho verificato che John the Ripper riusciva a individuare tutte le password, sia con le modalità predefinite sia con RockYou. La parte facoltativa mi ha fatto ragionare invece sulle priorità di risposta a un ransomware: contenere l'infezione, verificare l'estensione del problema e ripristinare i sistemi in sicurezza. Le prove di cracking sono state svolte esclusivamente nel laboratorio didattico; l'analisi su WannaCry è teorica.